

Security Assessment – 5 Questions and Answers

1. How would you evaluate the security risk associated with an exposed RPC service?

Answer:

1. Check whether the RPC service is accessible from external networks.
2. Identify its version and check for known vulnerabilities.
3. Verify whether authentication and access controls are enabled.
4. Check whether the service is necessary for the system.
5. An exposed and vulnerable RPC service can create a high security risk.

2. Why are Windows Null Sessions considered a security weakness, and how would you assess their impact?

Answer:

1. A Null Session may allow access without normal authentication.
2. It can reveal information about users, groups, or shared resources.
3. Attackers can use this information for further reconnaissance.
4. Check what information is accessible through the Null Session.
5. Restricting unnecessary anonymous access reduces the security risk.

3. How would you assess whether an NFS configuration exposes sensitive Linux files to unauthorized users?

Answer:

1. Check which directories are exported through NFS.
2. Identify which users or systems can access the exports.
3. Check whether the access is read-only or read-write.
4. Pay special attention to sensitive files and directories.
5. Unauthorized write access to sensitive files can create a high security risk.

4. A web application is vulnerable to SQL injection. How would you evaluate the severity of this vulnerability?

Answer:

1. Check whether the vulnerability allows unauthorized database access.
2. Determine whether sensitive user information can be exposed.
3. Check whether database records can be modified or deleted.
4. Determine whether authentication can be bypassed.
5. SQL injection is highly severe when it provides access to sensitive data or systems.

5. How would you evaluate the security of a mobile application using a tool such as MobSF?

Answer:

1. Use MobSF to analyze the application's security configuration.
2. Check for insecure data storage and hardcoded passwords or API keys.
3. Review permissions requested by the application.
4. Check communication security and possible vulnerabilities.
5. Manually verify important findings before reporting them.